

Universidad de la
Defensa Nacional

FADENA

Ciberseguridad aplicada

Clase 6: REPASO INTEGRAL

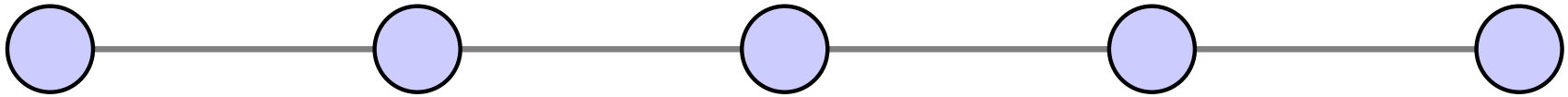
Unidades I a VII

11 de mayo de 2026

Ruta de la Clase 6: REPASO

BLOQUE FUNDAMENTOS (UNIDADES I-III)	**BLOQUE GESTIÓN Y CONTROL** (UNIDADES IV-VII)
▪ Espacio Cibernético ▪ Propiedades (Tríada CID) ▪ Riesgos y Amenazas	▪ Gestión de Activos (U. IV) ▪ Gestión de Riesgos (U. V) ▪ IAM (U VI) ▪ Gestión de vulnerabilidades y Segmentación (U VII)

Recorrido de la Clase 6 - Repaso



Tema 1
Fundamentos

Tema 2
Escenarios

Tema 3
Gestión Activos y
Gestión de
Riesgos

Tema 4
IAM Identidades
Usuarios
y Accesos

Tema 5
Gestión Vul-
nerabilidades
Superficie

Tema 1 **Ciberespacio:** Capas, Sujetos/Objetos y Tríada CID. (I y II)
Tema 2 **Riesgos y Amenazas:** El Blue, Red y Purple Team (III).
Tema 3 **Gestión de Activos (IV) y Riesgos (V):** Inventario y Tratamiento.
Tema 4 **IAM (VI):** Identidad, Autenticación y Autorización
Tema 5 **Vulnerabilidades y Segmentación (VII):** Reducción de superficie.

Unidad I: Fundamentos del Ciberespacio

El ciberespacio es un entorno de interacción socio-técnica multidimensional.

- **Capas principales:** Física (geografía/hardware), Lógica (redes/protocolos) y Social/Cognitiva (personas/identidades).
- **Entidades:**
  - **Sujeto:** Entidad activa que actúa (ej. Usuario, proceso).
  - **Objeto:** Entidad pasiva que recibe la acción (ej. Archivo, base de datos).

Ejemplo: Un sistema de radar militar aislado. No usa Internet, pero es parte del ciberespacio porque procesa datos, ejecuta software e interactúa con humanos.

Unidad I: Más que una red

Es fundamental no confundir los alcances de la seguridad:

Seguridad Informática: Se enfoca en proteger los sistemas, redes, hardware y software.

Seguridad de la Información: Más amplia. Garantiza la **tríada CID** (Confidencialidad, Integridad y Disponibilidad) en cualquier soporte: digital, físico (papel) o verbal .

Ciberseguridad: Surge con la hiperconectividad. Protege los activos y sistemas conectados dentro del ciberespacio.

Unidad I: La base de todo (Dependencias)

El ciberespacio no es abstracto; depende de una cadena de niveles físicos y lógicos. **Una falla en cualquier nivel impacta en todos los demás**.

Energía	$\rightarrow$	Base fundamental (Sin energía no hay sistema)
Hardware	$\rightarrow$	Procesamiento y almacenamiento físico
Sist. Operativo	$\rightarrow$	Control y gestión de recursos
Redes	$\rightarrow$	Comunicación y conectividad
Aplicaciones	$\rightarrow$	Servicios finales
Datos	$\rightarrow$	El valor estratégico
Usuario	$\rightarrow$	El propósito de la interacción

Unidad II: Propiedades de la Seguridad

La seguridad busca proteger el valor estratégico de la información.

- **Dato vs. Información:** El dato es el hecho bruto; la información es el dato con contexto.
- **Tríada CID:** Confidencialidad, Integridad y Disponibilidad.

Ejemplo:

- **Dato:** "42".
- **Información:** "42 usuarios accedieron al sistema hoy".
- **Priorización:** En datos personales, la prioridad es la **Confidencialidad**; en un sistema de control industrial, es la **Disponibilidad**.

Unidad II: Ciclo de Vida de la Información

La información no es estática; atraviesa etapas desde su origen hasta su destrucción. La seguridad debe aplicarse en **cada fase**.

- **Etapas principales:**
  1. Creación / Captura
  2. Almacenamiento
  3. Uso / Procesamiento
  4. Compartición / Distribución
  5. Archivo
  6. Eliminación segura

Idea clave: Cada etapa implica riesgos específicos y requiere controles adecuados (ej. el cifrado es vital en el almacenamiento y transporte, mientras que el borrado seguro lo es al final).

Unidad II: Propiedades Extendidas y Priorización

Más allá de la tríada CID, existen otras propiedades esenciales:

- **Autenticidad:** Asegura la identidad del origen.
- **Trazabilidad:** Registro de quién hizo qué y cuándo.
- **No Repudio:** Evita que alguien niegue una acción realizada.

Criterios de Priorización (Dependen del contexto):

- **Registros legales:** Prioridad en **Integridad y No repudio**.
- **Sistema Bancario:** Prioridad en **Disponibilidad e Integridad**.
- **Datos Personales:** Prioridad en **Confidencialidad**.

Unidad II: El Valor Estratégico de la Información

¿Por qué gestionamos la información como un **activo estratégico**?

- **Toma de decisiones:** Reduce la incertidumbre.
- **Ventaja competitiva:** Diferencia a la organización en el mercado.
- **Continuidad operativa:** Sin información, los procesos se detienen.

*"Protegemos datos a nivel técnico, pero el objetivo final es proteger el **conocimiento** y el **propósito** de la organización".*

Unidad III: Relación entre Conceptos

Para que ocurra un **incidente**, la amenaza debe encontrar y explotar una debilidad existente.

- **Amenaza:** Se clasifican en accidentales (fallas físicas), errores (uso o diseño) e intencionales (internas o remotas).
- **Vulnerabilidad:** Pueden ser **técnicas** (software/hardware), **organizativas** (procesos) o **humanas** (errores/desconocimiento)
- **Impacto:** Es la medida del daño sobre el activo en sus dimensiones CID. Sin vulnerabilidad, la amenaza no puede materializarse ni generar impacto.

Cálculo del Riesgo: Combinación de la frecuencia de ocurrencia y la severidad del daño.

$$\textbf{\textit{Riesgo} = \textit{Probabilidad} $\times$ \textit{Impacto}}$$

Unidad III: Enfoques Operativos Modernos

La ciberseguridad actual utiliza equipos con roles complementarios para reducir el riesgo.

- **Blue Team (Guardianes):** Se encarga del monitoreo continuo, la detección de intrusiones y la respuesta ante incidentes.
- **Red Team (Atacantes Controlados):** Simula ataques reales basados en técnicas de adversarios (como MITRE ATT&CK) para hallar fallos antes que los criminales.
- **Purple Team (Colaboración):** No es un equipo estático, sino una **dinámica de integración** donde ambos bandos comparten hallazgos para optimizar la seguridad global.

Unidad III: Ingeniería Social y Vulnerabilidad Humana

El eslabón más débil no suelen ser los sistemas, sino las personas.

- **Ingeniería Social:** El arte de manipular emociones como el miedo, la confianza o la urgencia para obtener datos.
- **Ejemplos de Vulnerabilidades:** Uso de contraseñas débiles, descuidos en el manejo de información sensible o exceso de confianza

Ejemplo de Ingeniería Social:

Victor Lustig convenció a un empresario de comprar la Torre Eiffel como chatarra usando el engaño y la persuasión, explotando la confianza y no un fallo técnico .

Kevin Mitnick demostró que un atacante puede vulnerar grandes empresas (como Motorola o el NORAD) simplemente usando su voz y técnicas de persuasión telefónica.

Unidad IV: Inventario y Clasificación

"No se puede proteger lo que no se conoce".

- **Categorías:** Datos, Software, Hardware, Redes, Personal, Instalaciones.
- **Roles:** Propietario (Owner), Responsable (Custodio) y Usuario.

Ejemplo de Dependencia: Un servicio web (activo de valor) depende del software del servidor, que depende del hardware, que a su vez depende de la infraestructura de energía.

Unidad IV: ¿Cómo identificamos los activos?

Existen dos metodologías principales para realizar el relevamiento, y en la práctica son **complementarias**:

- **Enfoque Top-Down (Orientado al Negocio):** Parte de los procesos y servicios críticos para identificar qué información los soporta . *Ventaja: Alineación directa con el riesgo de negocio*.
- **Enfoque Bottom-Up (Orientado a la Tecnología):** Parte del hardware y software existente para luego analizar su uso. *Ventaja: Asegura un relevamiento técnico completo*.

Dato clave: El inventario debe incluir no solo fierros, sino fundamentalmente los **activos de información** (bases de datos, credenciales, logs).

Unidad IV: Clasificación y Valoración (Tríada CID)

La clasificación permite determinar la **criticidad** y prioridad de protección de cada activo.

- **Confidencialidad:** ¿Qué daño produce su divulgación no autorizada?
- **Integridad:** ¿Qué impacto genera la pérdida de exactitud de los datos?
- **Disponibilidad:** ¿Cuánto tiempo puede estar el servicio caído antes de afectar la operación?

Ejemplo de Escala (Integridad):

- **Bajo (1):** No afecta al negocio.
- **Crítico (5):** El negocio no funciona si supera las 3 horas de falla.

Unidad IV: Gestión Continua del Activo

El inventario no es una foto estática; es un proceso vivo que acompaña al activo en su evolución.

- **Fases:** Alta (incorporación), Modificación (cambios de uso) y Baja (eliminación segura).
- **Atributos esenciales:** Nombre, Ubicación, Propietario (quién define el "qué") y Responsable (quién administra el cómo").

Riesgo de Gestión: Los inventarios desactualizados generan *shadow assets* (activos desconocidos), lo que aumenta peligrosamente la **superficie de ataque**.

Unidad V: Análisis y Tratamiento

El Riesgo es la combinación de Probabilidad e Impacto ($R = P \times I$).

- **Opciones de Tratamiento:** Mitigar (poner controles), Transferir (seguro), Aceptar o Evitar.
- **Riesgo Bruto vs. Residual:** El riesgo antes y después de aplicar salvaguardas.

Ejemplo: Si una base de datos tiene un riesgo bruto de 15, aplicar **MFA** (Autenticación Multifactor) puede reducir el riesgo residual a 9 al disminuir la probabilidad de acceso indebido.

Unidad V: El Proceso de Análisis de Riesgo

Gestionar riesgos no es eliminarlos, sino comprenderlos para decidir cómo tratarlos.

- **Pasos fundamentales del proceso:**
  1. **Identificación de activos:** Determinar qué se protege.
  2. **Identificación de amenazas y vulnerabilidades:** Reconocer eventos y debilidades.
  3. **Análisis de Impacto y Probabilidad:** Evaluar consecuencias y frecuencia.
  4. **Determinación y priorización:** Ordenar según nivel de criticidad.

Regla de Oro: La organización debe mantener **consistencia metodológica**. Una vez elegido un criterio de impacto (ej. máximo o suma de CID), debe aplicarse igual a todos los activos para que los resultados sean comparables.

Unidad V: La Matriz de Riesgo

La combinación de Probabilidad e Impacto se vuelca en una matriz para definir prioridades de acción.

- **Escala de Severidad:**
  - **Bajo (1–4):** Riesgo aceptable; requiere monitoreo.
  - **Medio (5–9):** Nivel para monitorear y seguir periódicamente.
  - **Alto (10–14):** Riesgo que debe ser tratado con controles.
  - **Extremo (15–25):** Requiere **acción inmediata**.

*En el ejemplo anterior, la aplicación de MFA bajó el riesgo de un nivel **Extremo** (15) a un nivel **Medio** (9).*

Unidad V: Ciclo de Gestión y Controles

El riesgo es **dinámico**: evoluciona con el entorno tecnológico y los cambios organizacionales.

- **Tipos de Controles (Salvaguardas):**
  - **Técnicos:** Firewalls, cifrado, MFA.
  - **Organizacionales:** Procesos, políticas y normativas.
  - **De Personal:** Capacitación y concientización.
- **Ciclo Iterativo:** Activos $\rightarrow$ Amenazas $\rightarrow$ Vulnerabilidades $\rightarrow$ Riesgo $\rightarrow$ Tratamiento $\rightarrow$ Monitoreo $\rightarrow$ Mejora.

Idea clave: El objetivo final es reducir el **riesgo bruto** hasta un nivel aceptable denominado **riesgo residual**.

Unidad VI: Gestión de Identidades y Accesos

Garantizar que solo quien debe acceder, acceda a lo necesario (Mínimo Privilegio).

- **Procesos:** Identificación, Autenticación (¿quién es?) y Autorización (¿qué puede hacer?).
- **Modelos:** RBAC (Roles), ABAC (Atributos), ACL (Listas).

Ejemplo Técnico (Linux): El comando `chmod 770` sobre un directorio crítico. Permite acceso total al **Propietario** y al **Grupo**, pero prohíbe cualquier acceso a **Otros**.

Unidad VI: IAM - Tres Procesos Relacionados

IAM es un concepto integrador que define quién accede a qué y en qué condiciones. Es vital diferenciar tres procesos clave:

- **Gestión de Identidades (Identity):** Responde a *¿quién es?* la entidad. Define los atributos únicos de la identidad digital.
- **Gestión de Usuarios (User):** Se encarga de materializar la identidad en sistemas (alta, baja y modificación de cuentas).
- **Gestión de Accesos (Access):** Responde a *¿qué puede hacer?*. Regula los permisos sobre recursos y servicios.

Nota Legal: El usuario debe **firmar formalmente** el documento de aceptación de responsabilidades. Lo que no está documentado, no existe jurídicamente.

Unidad VI: Autenticación (¿Es quien dice ser?)

La autenticación valida la identidad declarada mediante distintos factores:

- **Algo que sabe:** Contraseñas o PIN.
- **Algo que tiene:** Tokens, certificados digitales o teléfonos móviles.
- **Algo que es:** Biometría (huella, rostro, iris).

Buenas Prácticas:

- Uso de **MFA (Multifactor)** para cuentas privilegiadas.
- Implementación de **Zero Trust (ZTA):** "Nunca confiar, siempre verificar", sin importar la ubicación de red del usuario.

Unidad VI: Modelos de Autorización

Existen diferentes enfoques para implementar la autorización en los sistemas:

- **RBAC (Basado en Roles):** Los permisos se asignan a funciones (ej. "Analista") y los usuarios heredan permisos al ser asignados a ese rol.
- **ABAC (Basado en Atributos):** El acceso depende de condiciones del usuario, el recurso y el **entorno** (ej. horario o ubicación).
- **ACL (Listas de Control):** El permiso se define directamente sobre el objeto (como el ejemplo de `chmod`).

Principio Rector: Mínimo Privilegio. Otorgar solo los permisos necesarios durante el tiempo estrictamente necesario para la tarea.

Unidad VII: ¿Cómo detectamos las debilidades?

La detección es un proceso sistemático que combina herramientas y análisis técnico.

- **Métodos principales:**
  - **Escaneo automatizado:** Herramientas como Nessus o OpenVAS.
  - **Pentesting:** Simulación controlada de ataques para evaluar la seguridad real.
  - **Auditorías:** Revisión de configuraciones y cumplimiento de políticas.
- **Estándares de Identificación:**
  - **CVE (MITRE):** Identificador único para cada vulnerabilidad conocida.
  - **NVD (NIST):** Base de datos que analiza y enriquece los registros CVE.

Idea clave: CVE identifica la falla, mientras que NVD proporciona el análisis técnico y su severidad.

Unidad VII: Priorización y el sistema CVSS

No se puede corregir todo; la seguridad consiste en gestionar el orden de tratamiento según el riesgo.

- **CVSS (Common Vulnerability Scoring System):** Estándar abierto para asignar una puntuación de severidad.
- **Factores que evalúa CVSS:**
  - **Impacto en CIA:** Afectación a Confidencialidad, Integridad y Disponibilidad.
  - **Explotabilidad:** Facilidad de aprovechamiento y nivel de acceso requerido.
- **Objetivo:** Determinar qué vulnerabilidades se corrigen primero para optimizar recursos y reducir el riesgo operativo.

Unidad VII: Superficie de Ataque

Es el conjunto total de puntos que un atacante puede intentar explotar para acceder al sistema.

- **Elementos expuestos:** Puertos abiertos, servicios en escucha, APIs y credenciales débiles.
- **Estrategias de Reducción:**
  - **Hardening:** Deshabilitar servicios innecesarios.
  - **IAM:** Aplicar el principio de mínimo privilegio.
  - **Segmentación:** Limitar el **movimiento lateral** de un atacante.

Técnica clave: La **DMZ** actúa como zona intermedia, aislando servicios públicos sin exponer directamente la red interna (MZ).

Unidad VII: Reducción de la Superficie de Ataque

El objetivo es limitar la exposición y el movimiento lateral de un atacante.

- **Estándares:** CVE para identificar y CVSS para puntuar severidad.
- **Segmentación:** Uso de VLANs, Firewalls y DMZ.

Ejemplo de Arquitectura: Colocar el servidor web en una **DMZ** (Zona Desmilitarizada). Si el servidor es comprometido, el atacante no tiene acceso directo a la base de datos en la red interna (MZ).

¿Preguntas?

Pueden dejar sus consultas en el foro de la semana de repaso.

¡Éxitos en el examen!